

Анализ APK: pornhub (KIBIRIGE CONSULTANCY LIMITED)

Пакет: com.getfinesylabusfromtab • версия 1.0.3 (код 2) • разбор установочного набора, языковых кусков и декомпилированного кода

SDK / стек

Параметр	Значение
Название приложения	pornhub (внутреннее имя Bornbub, пакет com.getfinesylabusfromtab)
Android Gradle Plugin	8.11.0
minSdk	24
targetSdk	36
Kotlin	да 2.1.20
Web View	да
Custom Tabs	да
Рекламные сети	нет
Аналитика	нет
Permissions	android.permission.INTERNET, android.permission.READ_EXTERNAL_STORAGE, android.permission.SYSTEM_ALERT_WINDOW, android.permission.VIBRATE, android.permission.WRITE_EXTERNAL_STORAGE, android.permission.ACCESS_NETWORK_STATE, com.getfinesylabusfromtab.DYNAMIC_RECEIVER_NOT_EXPORTED_PERMISSION, com.android.vending.CHECK_LICENSE
Libraries	Expo SDK 54.0.0, React Native 0.81.4 (Hermes, New Architecture / Fabric), Kotlin 2.1.20, kotlincoroutines (core, android), expo-modules-core, expo-router, expo-updates, expo-web-browser, expo-splash-screen, expo-linking, expo-constants, expo-asset, expo-font, expo-haptics, expo-keep-awake, expo-blur, expo-linear-gradient, expo-system-ui, expo-file-system, expo-fetch, expo-manifests, expo-json-utils, expo-structured-headers, expo-eas-client, react-native-webview (RNCWebView), @react-native-async-storage/async-storage, react-native-reanimated, react-native-worklets, react-native-gesture-handler, react-native-screens, react-native-safe-area-context, react-native-svg + AndroidSVG (caverock), react-native-get-random-values (org.linusu), AndroidX: AppCompat 1.7, Core / Core-KTX, Core-SplashScreen, Activity, Fragment, Lifecycle, SavedState, Loader, Room + SQLite, Startup, ProfileInstaller, Emoji2, RecyclerView, ViewPager / ViewPager2, SwipeRefreshLayout, SlidingPaneLayout, CoordinatorLayout, DrawerLayout, CardView, CustomView, CursorAdapter, DocumentFile, DynamicAnimation, ExifInterface, Autofill, Interpolator, LocalBroadcastManager, Media, Print, Transition, Tracing, VectorDrawable, VersionedParcelable, Legacy-support-v4, AndroidX Browser (Custom Tabs), AndroidX WebKit, Google Material 1.12, OkHttp 4.12.0 + okhttp-brotli + Okio, Coil 3, Facebook SoLoader / Fresco / fbjni / Bolts Tasks, BlurView (eightbitlab), BouncyCastle, Brotli (org.brotli), Apache Commons Codec / IO, Google Play PAIRIP licensecheck
Поздирительные домены	config.ru

Параметр	Значение
SharedPreferences	dev.expo.EASSharedPreferences — ключ eas-client-id: постоянный уникальный номер установки, который создаётся при первом запуске и уходит на сервер в каждом запросе обновления; dev.expo.updates.prefs — локальное переопределение настроек обновлений; expo_ui_preferences — вид системных панелей; expo.modules.permissions.asked — какие разрешения уже спрашивали; expo.modules.kotlin.PersistentDataManager — служебные данные. Игровой прогресс хранится отдельно, в AsyncStorage: winner_slice_stats, winner_slice_settings, winner_slice_achievements; скачанные версии кода — в собственной базе expo-updates.
Есть ли клоака	да
Подозрительные слова	EXPO_UPDATES_CHECK_ON_LAUNCH = ALWAYS, EX_UPDATES_ANDROID_DELAY_LOAD_APP, expo-channel-name = production, expo-server-defined-headers, expo-manifest-filters, rollBackToEmbedded, noUpdateAvailable, checkForUpdateAsync, fetchUpdateAsync, reloadAsync, redirect (applyRedirects, setRedirect, getNameFromRedirectPath), whitelist / allowlist (originWhitelist, defaultOriginWhitelist, addWhitelistedNativeProps), loadUrl, openURL, canOpenURL, webView url (source.uri), bridge, license check (com.pairip.licensecheck, LicenseActivity), bornbub (схема ссылок и внутреннее имя, имитирующие бренд pornhub)

Проверка домена: config.ru

Формат как на VirusTotal → Security vendors' analysis, в конце три доп. пункта.

Параметр / движок	Значение / вердикт
Домен	config.ru
VirusTotal URL	https://www.virustotal.com/gui/domain/config.ru
Детекции	0/91 (malicious=0, suspicious=0)
Security vendors' analysis	ниже построчно, как на VirusTotal
Abusix	Clean
Acronis	Clean
ADMINUSLabs	Clean
AILabs (MONITORAPP)	Clean
AlienVault	Clean
alphaMountain.ai	Clean
Antiy-AVL	Clean
BitDefender	Clean
Blueliv	Clean
Certego	Clean
Chong Lua Dao	Clean
CINS Army	Clean
CMC Threat Intelligence	Clean
CRDF	Clean
CTX AI	Clean
Cyble	Clean
CyRadar	Clean
desenmascara.me	Clean

Параметр / движок	Значение / вердикт
Dr.Web	Clean
EmergingThreats	Clean
Emsisoft	Clean
ESET	Clean
ESTsecurity	Clean
Forcepoint ThreatSeeker	Clean
Fortinet	Clean
G-Data	Clean
Google Safe Browsing	Clean
GreenSnow	Clean
Heimdal Security	Clean
IPsum	Clean
Juniper Networks	Clean
Kaspersky	Clean
LevelBlue	Clean
Lionic	Clean
Malwareid	Clean
MalwarePatrol	Clean
OpenPhish	Clean
Phishing Database	Clean
Phishtank	Clean
PREBYTES	Clean
Quick Heal	Clean
Quttera	Clean
Scantitan	Clean
SCUMWARE.org	Clean
Seclookup	Clean
Sophos	Clean
StopForumSpam	Clean
Sucuri SiteCheck	Clean
ThreatHive	Clean
URLhaus	Clean
Viettel Threat Intelligence	Clean
ViriBack	Clean
VX Vault	Clean
Webroot	Clean
Xcitium Verdict Cloud	Clean
Yandex Safebrowsing	Clean
ZeroCERT	Clean

Параметр / движок	Значение / вердикт
0xSI_f33d	Unrated
AlphaSOC	Unrated
ArcSight Threat Intelligence	Unrated
AutoShun	Unrated
Axur	Unrated
Bfore.Ai PreCrime	Unrated
Bkav	Unrated
ChainPatrol	Unrated
Cluster25	Unrated
Criminal IP	Unrated
CSIS Security Group	Unrated
Cyan	Unrated
DNS8	Unrated
Ermes	Unrated
Fortra	Unrated
GCP Abuse Intelligence	Unrated
GreyNoise	Unrated
Gridinsoft	Unrated
Guardpot	Unrated
Hunt.io Intelligence	Unrated
Lumu	Unrated
MalwareURL	Unrated
Mimecast	Unrated
Netcraft	Unrated
PhishFort	Unrated
PrecisionSec	Unrated
SafeToOpen	Unrated
Sansec eComscan	Unrated
SecureBrain	Unrated
Snort IP sample list	Unrated
SOCRadar	Unrated
URLQuery	Unrated
VIPRE	Unrated
ZeroFox	Unrated
Куда редиректит	нет
Что выводит (кратко)	не удалось открыть (ReadTimeout)
Где припаркован	регистратор: RU-CENTER-RU

Какие данные собираются

- **тип телефонной системы** → приложение сообщает, что запрос пришёл именно с Android-телефона (в запросе это пометка «Expo-Platform: android»); по ней сервер понимает, какой набор кода можно этому человеку отдать
- **постоянный уникальный номер установки** → служебный номер, который приложение придумывает себе при первом же запуске и навсегда сохраняет в своей памяти (пометка «EAS-Client-ID», хранится в файле настроек dev.expo.EASSharedPreferences под ключом eas-client-id). Это фактически метка устройства: по ней сервер отличает один телефон от другого и может стабильно выдавать конкретному телефону конкретный вариант приложения
- **версия начинки приложения** → номер «сменного содержимого», под которое собрана эта установка (пометка «Expo-Runtime-Version», здесь 1.0.3); сервер по нему выбирает подходящий пакет и не присылает несовместимый
- **название канала раздачи** → имя «полки» на сервере, с которой этому телефону берут содержимое (пометка «expo-channel-name: production», она вшита в настройки приложения). Владелец может держать на разных полках разное содержимое и переключать их без обновления приложения в магазине
- **номер той версии кода, которая сейчас работает** → пометка «Expo-Current-Update-ID»; по ней сервер видит, что человеку уже успели подsunуть, и не повторяется
- **номер версии кода, вшитой в установочный файл** → пометка «Expo-Embedded-Update-ID»; сервер видит, находится телефон на «заводском» (магазинном) содержимом или уже на подменённом
- **номера версий кода, которые на этом телефоне не смогли запуститься** → пометка «Expo-Recent-Failed-Update-IDs»; сервер узнаёт, что именно у этого человека сломалось, и может прислать другой вариант
- **текст последней аварии приложения** → первые 1024 символа сообщения об ошибке из последнего падения (пометка «Expo-Fatal-Error»); это, по сути, кусок внутреннего журнала телефона, который уходит наружу
- **произвольные дополнительные пометки** → набор пар «название — значение», который приложение хранит у себя и подставляет в запрос (пометка «Expo-Extra-Params»); состав этих пометок задаётся не человеком, а стороной, которая управляет содержимым
- **дополнительные поля, которые ранее назначил сам сервер** → самое важное: в предыдущем ответе сервер может сказать «в следующий раз присылай мне ещё вот эти сведения» (пометка «expo-server-defined-headers»). Приложение сохраняет такой список у себя и послушно добавляет его в каждый следующий запрос, то есть перечень собираемых данных можно менять удалённо, уже после установки
- **служебные пометки способа связи** → Accept, «Expo-Protocol-Version: 1», «Expo-API-Version: 1», «Expo-Updates-Environment: BARE», «Expo-JSON-Error: true», а при включённой подписи ещё и «expo-expect-signature»; сами по себе они безобидны и нужны, чтобы сервер понял формат разговора
- **как представился сетевой клиент** → строка «okhttp/4.12.0»; по ней сервер сразу видит, что к нему обращается не обычный браузер человека, а программа внутри телефона — по такому признаку удобно отделять живых людей от проверяющих
- **адрес выхода в интернет** → отдельно приложение его не отправляет, но сервер видит его сам у любого запроса; именно по нему обычно определяют страну, город и оператора человека, а значит и решают, что ему показывать

Как собираются

Всё это приложение забирает само, без единого вопроса человеку: отдельного окна с разрешением здесь не появляется, потому что ни язык, ни камера, ни местоположение не

запрашиваются — берутся только собственные служебные записи приложения и стандартные ответы системы Android.

Сбор идёт дважды и оба раза в момент запуска. Сначала это делает встроенная часть приложения на языке Android: в настройках сборки прямо указано «проверять при каждом запуске» (`EXPO_UPDATES_CHECK_ON_LAUNCH = ALWAYS`) и «задержать показ приложения, пока проверка не закончится» (`EX_UPDATES_ANDROID_DELAY_LOAD_APP = true`). Затем ту же проверку повторяет главный экран приложения: в самом верхнем слое интерфейса (`RootLayout`) вызывается небольшая подпрограмма `useCheckUpdates`, которая обращается к серверу и сама ставит десятисекундный предохранитель.

Пока эта проверка идёт, человек видит не игру, а пустой белый экран с крутящимся кружком ожидания. Если сервер не ответил за 10 секунд, предохранитель срабатывает и приложение всё-таки пускает человека дальше. То есть задержка на старте — это не «медленная загрузка», а ожидание ответа на вопрос «что этому человеку показывать».

Откуда берутся значения: уникальный номер установки читается из файла настроек приложения (`dev.expo.EASSharedPreferences`), номера версий кода — из собственной базы приложения, где записаны все ранее скачанные пакеты, название канала и адрес сервера — из вшитых при сборке параметров, текст аварии — из файла журнала ошибок, который приложение ведёт само.

Отдельно отмечу по итогам полного просмотра кода, ресурсов и всех текстовых строк: язык телефона, рекламный номер устройства, модель, оператор и часовой пояс в этой сборке никуда не отправляются — таких вызовов в приложении нет. Разделение людей здесь строится не на этих сведениях, а на метке устройства, канале раздачи и адресе выхода в интернет, который сервер видит сам.

Куда отправляются

Запрос уходит на один точный адрес:

<https://u.expo.dev/caa153df-6c84-4653-870d-0ba49e26348c>. Он вшит в настройки приложения при сборке (пункт `expo.modules.updates.EXPO_UPDATE_URL` в общем описании программы), поэтому человек его никак не видит и изменить не может. Ссылка не собирается из кусков и не маскируется — она лежит открытым текстом.

Запасных адресов в приложении нет, но подменить адрес всё-таки можно: приложение умеет читать локальное переопределение настроек обновлений из файла `dev.expo.updates.prefs`. Файлы самого содержимого (картинки, шрифты, куски кода) приложение потом качает с сети выдачи <https://classic-assets.eascdn.net/~assets/>, и в этих запросах снова отправляется постоянный номер установки.

Запрос выполняется тихо, в фоне, без всяких значков и уведомлений — обычным сетевым инструментом `OkHttp`. Ответ не выбрасывается: приложение складывает его в свою внутреннюю базу — сохраняет и описание версии кода, и присланные сервером дополнительные поля, чтобы отправлять их при следующем запуске.

Про «`config.ru`» из таблицы: это не сервер приложения, а имя языкового куска установочного набора для русского языка (файл `config.ru.apk`, рядом с `config.en.apk` и `config.zh.apk`). Автоматическая проверка приняла имя файла за адрес сайта. Приложение с этого адреса ничего не загружает, никакой связи с описанной здесь схемой у него нет.

Что возвращается

Ответ сервера — это не картинка и не реклама, а короткое указание, что делать дальше. Возможны ровно три варианта, и все три прямо разобраны в коде.

Первый вариант: сервер присылает описание новой версии содержимого вместе со ссылками на файлы. Приложение смотрит признак «есть доступное обновление» (`isAvailable`), скачивает

файлы и перезапускает себя уже с новым кодом. Важно, что меняется не картинка внутри игры, а вообще всё содержимое приложения — по этому каналу можно прислать любой экран, в том числе такой, которого в магазине никогда не проверяли.

Второй вариант: сервер отвечает «новой версии нет» (в коде это ответ `noUpdateAvailable`). Тогда предохранитель снимается, и человеку остаётся обычное приложение, вшитое в установочный файл.

Третий вариант — самый показательный: сервер отвечает «вернись к встроенной версии» (`rollBackToEmbedded`). Это прямая команда откатить человека назад на «магазинную», безобидную начинку. То есть у стороны, которая держит сервер, есть обе кнопки: и «показать этому телефону подменённое содержимое», и «показать ему обычное приложение».

Кроме самого решения сервер может прислать ещё два управляющих набора: «фильтры» (`expo-manifest-filters`), по которым приложение само отсеивает неподходящие ему версии, и «свои дополнительные поля» (`expo-server-defined-headers`), которые приложение обязано присылать в дальнейшем. Проверка подписи присланного кода в этой сборке не настроена: сертификата для проверки в описании программы нет, поэтому приложение принимает то, что пришло с этого адреса, без сверки подлинности.

Как показывается оффер или белая версия

Механика показа здесь необычная и поэтому её легко не заметить: подменённое содержимое открывается не отдельным окном сайта и не переходом в браузер, а подменой самого приложения. Приложение скачивает присланный пакет и само себя перезапускает (в коде это цепочка `checkForUpdateAsync` → `fetchUpdateAsync` → `reloadAsync`). Человек в этот момент видит только белый экран с кружком ожидания, а после него — уже другой экран, которого в установочном файле не было.

Момент показа — сразу при запуске, до появления любого содержимого: сборка настроена задерживать приложение до окончания проверки, а верхний слой интерфейса держит кружок ожидания до 10 секунд. Никакого нажатия от человека не требуется.

Инструменты, чтобы после подмены открыть внешнюю страницу, в приложении уже лежат готовыми: встроенное окно сайта внутри приложения (`react-native-webview`), быстрый браузерный лист поверх приложения (`expo-web-browser` вместе с системным `AndroidX Browser`) и переход по обычной ссылке наружу (`openURL`). Во вшитой версии они задействованы иначе: встроенное окно сайта используется только как звуковой движок и загружает готовый кусок разметки из памяти приложения, никакого внешнего адреса там нет. То есть сама «труба» для открытия рекламной страницы собрана и готова, а конкретный адрес должен прийти с сервера.

На то, что вшитая версия — прикрытие, указывает и несовпадение вывесок: в магазине приложение называется «pornhub», внутреннее имя и схема ссылок — «bornhub» (то есть подделка под известный взрослый бренд), а вшитое содержимое — обычная аркада про нарезание еды. Такой разрыв между обещанием и вшитым содержимым — типичный признак «белой» сборки, которая ждёт подмены содержимого с сервера.

Если же сервер ответил «новой версии нет» или «вернись к встроенной версии», никакой внешней страницы не открывается — человеку просто остаётся обычное приложение.